PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Sélection de logiciels libres

03-210 ANSSI - Sélection d'un logiciel libre — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. L'analyse historique d'un projet repose sur la date de création, la régularité des contributions et la maturité évaluée via le SILL.
2. L'évaluation du maintien en condition de sécurité nécessite de vérifier la procédure publique de gestion des vulnérabilités et le temps de correction des failles critiques.
3. Le socle technique (documentation, configuration par défaut, standards ouverts) se complète des pratiques déclarées : guides de développement, revue par les pairs, binaires reproductibles.

Analyse du projet

Notion	À retenir
Analyse historique	Prendre en compte : **date de création**, **régularité des contributions**, **nombre et expérience des principaux contributeurs**, et **maturité** (version bêta, écosystème, utilisateurs, presse professionnelle ou **SILL**).
Maintien opérationnel	Évaluer via : **mainteneurs désignés**, **commits et versions récentes** (dernière année), **correction des bugs fonctionnels** et **évolutions de l'écosystème** (plateformes, bibliothèques).

Évaluation du MCS et des dépendances

Notion	À retenir
Évaluation du MCS	Vérifier : **point de contact** sécurité, **procédure publique** de gestion des vulnérabilités, nombre de **correctifs** et **temps de correction** des vulnérabilités critiques.
Inventaire dépendances	Vérifier : **liste de dépendances** ou **SBOM** (`SPDX` ou `CycloneDX`), mise à jour, absence de vulnérabilités et usage d'**outils de gestion** incluant les vulnérabilités.
Analyses tiers	Identifier : **visa de sécurité de l'ANSSI** ou **rapports d'évaluation** de la communauté open source.

Qualité technique et pratiques de développement

Notion	À retenir
Le socle technique	Présence de **documentation** (utilisateur/administrateur), **configuration par défaut**, **recommandations de déploiement sécurisé** et usage de **standards/protocoles ouverts**.
Pratiques de développement	Conformité aux guides (**ANSSI** pour `C` et `Rust`, **OWASP**, **NSA** sur la gestion mémoire), **revue de code par les pairs**, **analyse outillée**, **tests unitaires**, **intégration continue** et **reproductibilité des binaires**.
Audit des contributions	Audit régulier combinant **analyse manuelle et outillée** pour prévenir l'insertion de **code illégitime** (ex: porte dérobée dans **XZ Utils**).

Le soutien au projet

Notion	À retenir
Besoins exprimés	Vérifier les **appels au soutien** (financier, contributeurs, maintenance, code, sécurité) : ils témoignent de la **santé** du projet.
Contrat de support	Souscrire si possible un **support fonctionnel ou de sécurité** (communauté ou entité commerciale) : **stabilité financière et pérennité** du projet, entité **rassurée**.

Pièges et confusions

- ⚠ Croire qu'un projet doit obtenir un score parfait sur l'ensemble des critères pour être sélectionné.
- ⚠ Penser que l'objectif de l'évaluation est d'exclure tout projet imparfait.
- ⚠ Oublier que l'audit des contributions doit être régulier même pour un projet établi pour prévenir l'insertion d'une porte dérobée.
- ⚠ Confondre l'objectif de prise de conscience des enjeux de cybersécurité avec une obligation de perfection absolue.

Sigles et définitions

MCO	ensemble des actions garantissant qu'un logiciel reste fonctionnel
MCS	garantit qu'un logiciel reste sécurisé
SILL	référentiel utilisé pour estimer la maturité d'un projet open source
SBOM	liste des dépendances d'un projet logiciel, dans un format tel que SPDX ou CycloneDX
OSSF	organisation qui publie un guide sur le processus de divulgation des vulnérabilités
OWASP Developer Guide	guide de référence sur les pratiques de développement sécurisé
porte dérobée	code malveillant inséré illégitimement dans un projet

Auto-test

1. Quels sont les deux formats possibles pour un SBOM ?
2. Quel projet est cité comme exemple d'insertion de porte dérobée ?
3. Que désigne le terme MCO ?
4. Quelle organisation publie un guide sur la divulgation des vulnérabilités ?
5. Quels guides sont cités pour les pratiques de développement ?

Réponses : **1.** SPDX ou CycloneDX · **2.** XZ Utils · **3.** maintien en condition opérationnelle · **4.** L'OSSF · **5.** Guides ANSSI (C, Rust), OWASP Developer Guide, guide NSA sur la gestion mémoire.

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.